

Spécifications fonctionnelles et techniques — version 2

(2026-07-11)

La v1 du 23/06 (26 pages, [../historique/2026-06/SPECIFICATIONS-FONCTIONNELLES-ET-TECHNIQUES.md](#)) est conservée intacte comme preuve de conception. Cette v2 spécifie l'application réellement livrée (lots A → L) et renvoie aux documents dédiés plutôt que de les recopier.

1. Périmètre et besoin

Renvoi : [expression-du-besoin-v2.md](#) (besoin, objectifs, critères d'acceptation adossés aux tests, hors-périmètre).

MoniteurConnect met en relation les auto-écoles qui recrutent et les moniteurs qui recherchent une mission ou un emploi. La plateforme rend le recrutement traçable de l'annonce au contrat signé, tout en limitant les comptes aux écoles et à l'administration afin de conserver un parcours candidat simple.

2. Spécifications fonctionnelles

Vue d'ensemble : [decoupage-fonctionnel.md](#) et [diagramme-fonctionnel-v2.md](#) .

Moniteur / candidat — sans compte

Fonction	Règles de gestion essentielles	Routes	Tests
Consulter et filtrer les annonces	Recherche par mots-clés, département, ville et rayon ; seules les annonces ouvertes d'écoles actives sont publiques.	GET /annonces	lot-e.cjs , smoke.cjs
Basculer en vue carte	La carte utilise les coordonnées déjà enregistrées ; aucun géocodage n'est déclenché à l'affichage.	GET /annonces?vue=carte	lot-e.cjs
Voir le détail d'une annonce	Une annonce absente ou non publiable renvoie 404 ; la vue incrémente le compteur sans bloquer la réponse.	GET /annonces/:id	lot-e.cjs , lot-h.cjs
Postuler avec pièces jointes	CV et justificatifs sont stockés hors public/ après limites de taille, mimetype, magic bytes et CSRF multipart.	POST /annonces/:id/postuler	correctifs.cjs , ameliorations.cjs
Empêcher une candidature back-office	Une session école ou admin est rejetée avant le limiteur anti-spam ; le candidat public reste sans compte.	POST /annonces/:id/postuler	ameliorations.cjs , ameliorations-v2.cjs
Suivre sa candidature	Le lien contient un jeton opaque ; la page de suivi n'expose aucune donnée personnelle dans l'URL.	GET /suivi/:token	lot-b.cjs

Fonction	Règles de gestion essentielles	Routes	Tests
Signer le contrat en ligne	La signature accepte le pad ou un import PNG/JPEG contrôlé ; elle n'est ouverte qu'après l'envoi du contrat par l'école.	GET/POST /suivi/:token/signer	lot-g.cjs
Télécharger le contrat	Avant signature, le PDF proposé est servi ; après signature, le PDF final et son empreinte SHA-256 font foi.	GET /suivi/:token/contrat	lot-g.cjs
S'abonner aux alertes email	Département et mot-clé sont enregistrés avec double opt-in ; le jeton de confirmation est haché.	GET/POST /alertes , GET /alertes/confirmer/:token	lot-i.cjs
Se désabonner	Une page de confirmation précède le POST ; le désabonnement supprime réellement l'alerte.	GET/POST /alertes/desabonner/:token	lot-i.cjs

Auto-école — compte requis

Fonction	Règles de gestion essentielles	Routes	Tests
S'inscrire	Email et SIRET sont uniques ; le SIRET peut être vérifié par Sirene, l'adresse géocodée et l'email confirmé avant connexion.	GET/POST /inscription , GET /verifier-email/:token	correctifs.cjs , lot-f.cjs , lot-l.cjs
Se connecter et se déconnecter	La connexion régénère la session ; les espaces école et admin restent cloisonnés.	GET/POST /connexion , POST /deconnexion	ameliorations-v2.cjs
Réinitialiser le mot de passe	Le jeton expirant est validé dès le GET ; la réinitialisation détruit les autres sessions de l'école.	GET/POST /mot-de-passe-oublie , GET/POST /reinitialiser/:token	ameliorations-v2.cjs
Gérer son profil	L'école modifie téléphone et adresse ; l'adresse bénéficie de l'autocomplétion et du géocodage.	GET/POST /mon-compte	lot-e.cjs , lot-l.cjs
Consulter ses statistiques	Le dashboard affiche tuiles, série sur 12 semaines, entonnoir et annonces les plus vues, toujours scopés par schoolId .	GET /tableau-de-bord	lot-h.cjs
Créer une annonce	Les champs sont validés et l'alerte aux abonnés est déclenchée sans bloquer la publication.	GET /mes-annonces/nouvelle , POST /mes-annonces	lot-a.cjs , lot-i.cjs

Fonction	Règles de gestion essentielles	Routes	Tests
Modifier une annonce	Seule l'école propriétaire peut modifier ; toute requête de gestion est scopée par <code>schoolId</code> .	GET/POST <code>/mes-annonces/:id/modifier</code>	<code>lot-a.cjs</code> , <code>correctif s.cjs</code>
Clôturer ou supprimer une annonce	Une annonce peut être clôturée ou supprimée, jamais rouverte ; la suppression nettoie les fichiers dépendants.	POST <code>/mes-annonces/:id/cloturer</code> , POST <code>/mes-annonces/:id/supprimer</code>	<code>lot-a.cjs</code> , <code>correctif s.cjs</code>
Consulter les candidatures et pièces	La liste est paginée par annonce ; seuls les fichiers de l'école propriétaire sont téléchargeables.	GET <code>/mes-annonces/:id/candidatures</code> et routes de pièces	<code>lot-a.cjs</code> , <code>correctif s.cjs</code>
Refuser une candidature	Le refus date <code>rejectedAt</code> , notifie le candidat et rend la candidature éligible à la purge après le délai RGPD.	POST <code>/mes-annonces/:id/candidatures/:appId/refuser</code>	<code>lot-b.cjs</code> , <code>lot-j.cjs</code>
Accepter et signer le contrat	L'école renseigne les termes et signe ; le PDF proposé et son SHA-256 sont produits. Une réédition invalide les signatures et le PDF final précédents.	GET/POST <code>/mes-annonces/:id/candidatures/:appId/accepter</code>	<code>lot-g.cjs</code>
Envoyer et télécharger le contrat	L'envoi ouvre la signature candidat ; l'école télécharge le PDF proposé ou le contrat contresigné final.	POST <code>/mes-annonces/:id/candidatures/:appId/contrat/envoyer</code> , GET <code>/mes-annonces/:id/candidatures/:appId/contrat/telecharger</code> , GET <code>/mes-annonces/:id/candidatures/:appId/contrat/telecharger-signer</code>	<code>lot-g.cjs</code>

Administrateur — espace cloisonné

Fonction	Règles de gestion essentielles	Routes	Tests
Se connecter à l'administration	La session est régénérée et ne donne pas accès à l'espace école.	GET/POST <code>/admin/connexion</code>	<code>lot-c.cjs</code> , <code>ameliorations-v2.cjs</code>
Consulter les statistiques plateforme	Le dashboard agrège écoles, annonces, candidatures et activité récente.	GET <code>/admin</code>	<code>lot-h.cjs</code>
Suspendre ou réactiver une école	La suspension bloque l'accès et masque ses annonces publiques ; l'école n'est pas supprimée.	POST <code>/admin/ecoles/:id/suspendre</code> , POST <code>/admin/ecoles/:id/reactiver</code>	<code>lot-c.cjs</code>

Fonction	Règles de gestion essentielles	Routes	Tests
Retirer une annonce	La modération supprime une annonce désignée ; seule une absence Prisma P2025 devient une 404.	POST /admin/annonces/:id/supprimer	lot-c.cjs , correctifs.cjs
Lancer la purge RGPD	La purge manuelle applique les mêmes règles que la tâche planifiée et journalise un PurgeRun .	POST /admin/purge	lot-j.cjs

Matrice des rôles et permissions

Qui peut faire quoi, et **quel code l'impose** (reprend le §1.7 de la v1, aligné sur les gardes réellement montées dans `src/routes/index.js`) :

Zone (routes)	Visiteur / candidat	École authentifiée	Admin	Garde dans le code
Consultation publique (/ , /annonces , détail, carte)	Oui	Oui	Oui	Aucune — pages publiques ; les annonces d'écoles suspendues sont masquées
Déposer une candidature (POST /annonces/:id/postuler)	Oui	Non	Non	<code>rejectBackOfficeApplication</code> : toute session back-office est refusée avant le limiteur anti-spam
Alertes email (/alertes , confirmation, désabonnement)	Oui	Oui (entrée de menu masquée)	Oui (entrée masquée)	Jetons hachés ; suppression réelle au désabonnement
Suivi et signature candidat (/suivi/:token , /signer)	Sur jeton uniquement	Idem (le lien fait foi)	Idem	Jeton opaque 64 hex ; signer depuis le suivi neutralise la session école du navigateur
Inscription / connexion / réinitialisation	Oui	Redirigée (déjà connectée)	—	<code>redirectIfAuth</code> ; connexion et reset régénèrent la session
Espace école (/tableau-de-bord , /mes-annonces , /mon-compte)	Redirection connexion	Oui, ses données seulement	Non	<code>requireAuth</code> + <code>loadSchool</code> ; toute requête de gestion scopée <code>schoolId</code>
Pièces et contrats d'une autre école	—	404	—	Scoping <code>schoolId</code> dans chaque service (prouvé par <code>test/smoke.cjs</code>)
Espace admin (/admin , écoles, annonces, purge)	Redirection login admin	Non	Oui	<code>requireAdmin</code> + <code>loadAdmin</code> ; la connexion admin régénère la session et ferme l'espace école
APIs relais (/api/siret/:siret , /api/adresse)	Oui	Oui	Oui	Rate-limit par IP (30/15 min et 30/min), réponses d'erreur non bloquantes

Transversal à toutes les écritures : jeton CSRF obligatoire (y compris formulaires multipart) et CSP stricte sans inline. Cloisonnement école/admin prouvé par `test/lot-c.cjs` et `test/ameliorations-v2.cjs` (« session admin ne peut pas atteindre /tableau-de-bord », « session école ne peut pas atteindre /admin »).

Maquettes v2

Les 30 écrans et états ci-dessus sont maquetés en filaire sous [wireframes-v2/](#) (livrés le 2026-07-11) ; la traçabilité écran → route → vue → tests est tenue dans [wireframes-v2/matrice-couverture.md](#) . Les maquettes v1 de juin restent intactes en preuve de conception initiale.

3. Spécifications techniques

- **Stack et justifications** : Node.js CommonJS, Express 5, Twig avec autoescape, Prisma (SQLite en développement, trajectoire PostgreSQL documentée), sessions en base et Leaflet auto-hébergé. Les alternatives rejetées sont explicitées dans le deck et [soutenance/questions-reponses.md](#) .
- **Données** : [base-de-donnees.md](#) documente les 8 modèles, les migrations et les procédures de sauvegarde/restauration.
- **Sécurité** : mots de passe hachés avec bcrypt, CSRF global y compris après upload multipart, CSP stricte sans inline, scoping `schoolId` , contrôle des magic bytes, rate-limits et purge RGPD. La veille associée est [veille-securite.md](#) .
- **Interfaces externes** : Sirene passe par `/api/siret/:siret` avec cache d'une heure et réponse d'erreur non bloquante ; l'API Adresse passe par `/api/adresse` avec cache de dix minutes, timeout et liste vide en panne. L'email utilise SMTP/Mailpit ; sans SMTP le lien est journalisé, et un échec d'envoi renvoie `false` sans faire échouer le parcours métier.
- **Qualité** : développement TDD, 15 suites et 448 assertions ; conformité W3C, axe et responsive rejouée le 2026-07-11 dans [conformite.md](#) ; règles visuelles dans [charte-graphique.md](#) .

4. Contraintes et limites assumées

L'environnement PostgreSQL de production n'a pas encore été démontré : il reste le seul critère à renforcer dans l'audit. En local, les emails sont inspectés avec Mailpit. Le pad de signature sur canvas dispose d'une alternative accessible par import d'image PNG ou JPEG, mais la signature électronique mise en œuvre n'est pas présentée comme une signature qualifiée au sens eIDAS.